

Network Reconnaissance & Host Discovery

Week 2 – Penetration Testing Lab Assignment

Prepared by:	Gokul R
Assignment:	Week 2 – Reconnaissance & Scanning
Tools Used:	theHarvester, Nmap / Zenmap
Test Environment:	Kali Linux (VM)
Report Date:	22 September 2026

Note: Screenshots in this report have been redacted to mask the target domain name and internal lab IP addresses in line with responsible-disclosure and lab confidentiality practice. All testing was performed in an isolated lab environment for academic purposes only.

1. Objective

The objective of this Week 2 assignment was to perform the reconnaissance phase of a penetration test, covering both passive open-source intelligence (OSINT) gathering and active host discovery on a lab network. The assignment was carried out in two parts:

- **Part A – Passive Reconnaissance:** Using theHarvester to enumerate subdomains, hosts and other public information about a target domain from open-source intelligence engines.
- **Part B – Active Host Discovery:** Using Nmap (via the Zenmap GUI) to identify live hosts on a local lab subnet through a ping sweep.

2. Tools Used

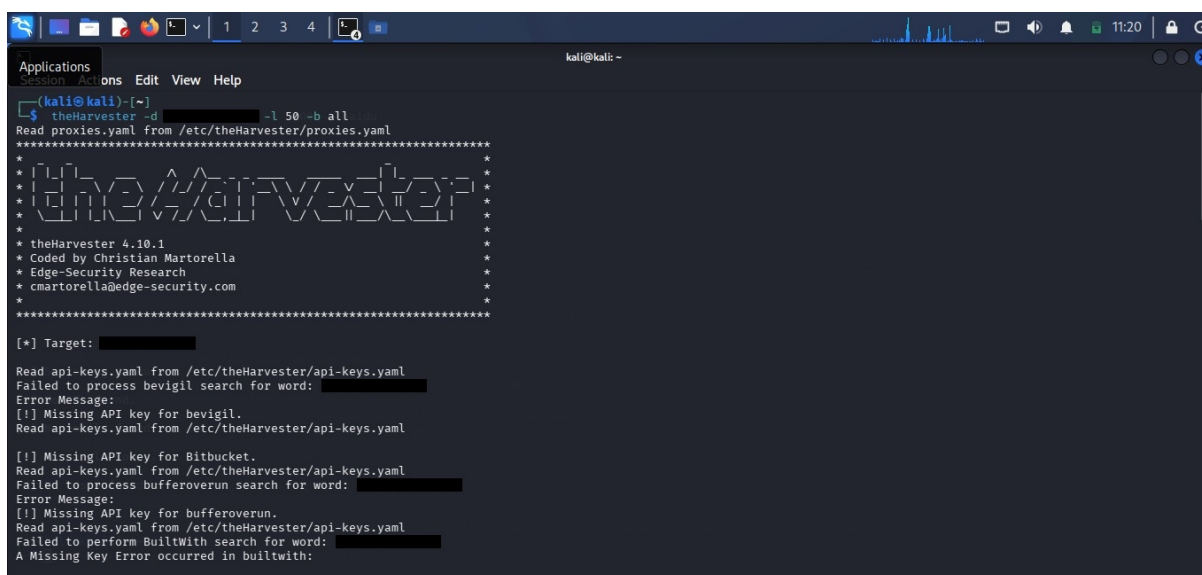
Tool	Purpose
theHarvester v4.10.1	OSINT gathering – subdomains, hosts, emails from public sources
Nmap / Zenmap 7.991	Active network scanning and host discovery (ping sweep)
Kali Linux	Penetration testing operating system used as the attack platform

3. Part A – Passive Reconnaissance with theHarvester

theHarvester was used to passively gather information about the target organisation's domain from open-source intelligence sources, without directly interacting with the target's infrastructure. The domain name has been redacted throughout this report; it is referred to generically as **<target-domain>**.

3.1 Initial scan – all sources

The scan was launched with the command `theHarvester -d <target-domain> -l 50 -b all`, instructing theHarvester to query all supported OSINT source engines and limit results to 50 per source. Several sources (bevigil, Bitbucket, bufferoverrun, BuiltWith, SecurityScorecard) returned "Missing API key" errors, since no API keys were configured for these premium sources in the lab environment.

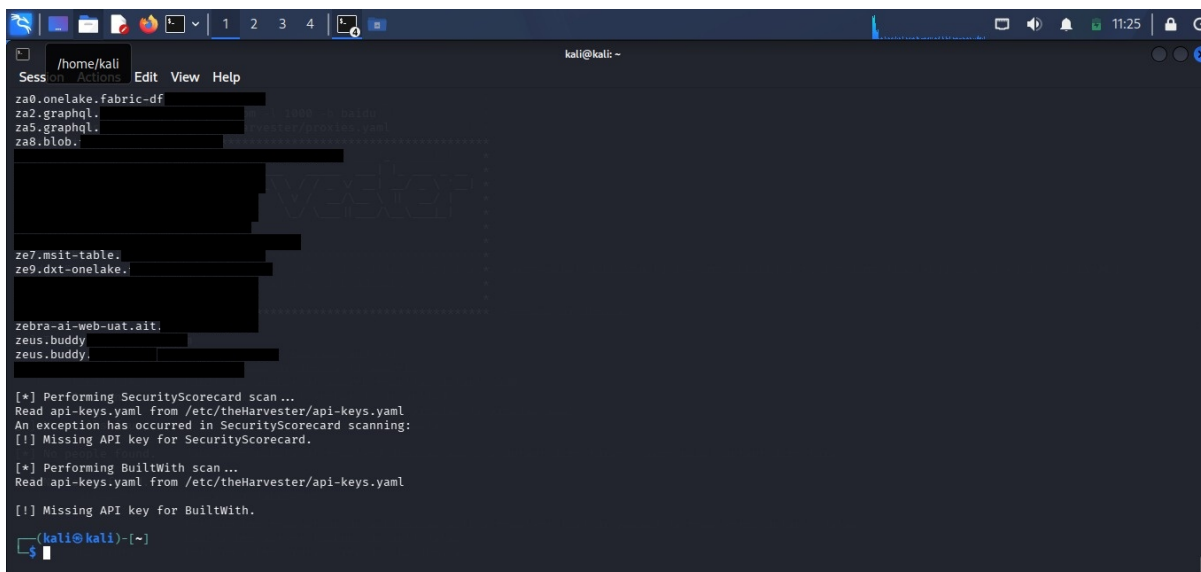


```
kali@kali: ~  
$ theHarvester -d [REDACTED] -l 50 -b all  
Read proxies.yaml from /etc/theHarvester/proxies.yaml  
*****  
* theHarvester 4.10.1  
* Coded by Christian Martorella  
* Edge-Security Research  
* cmartorella@edge-security.com  
*  
*****  
[*] Target: [REDACTED]  
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml  
Failed to process bevigil search for word: [REDACTED]  
Error Message:  
[!] Missing API key for bevigil.  
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml  
[!] Missing API key for Bitbucket.  
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml  
Failed to process bufferoverrun search for word: [REDACTED]  
Error Message:  
[!] Missing API key for bufferoverrun.  
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml  
Failed to perform BuiltWith search for word: [REDACTED]  
A Missing Key Error occurred in builtwith:
```

Figure 1: theHarvester launched against the target domain with '-b all' (11:20)

3.2 Scrolled output – discovered subdomains

Scrolling through the output revealed a large number of legitimate subdomains belonging to the target's cloud/API infrastructure (e.g. Fabric, AIT, and Cosmos-related hosts), confirming that theHarvester's free sources were still able to passively enumerate a meaningful subdomain footprint even without the paid API integrations. The tool then proceeded to attempt SecurityScorecard and BuiltWith scans, both of which failed due to missing API keys.

A terminal window on a Kali Linux system showing the output of a subdomain enumeration tool. The output lists several subdomains: za0.onelake.fabric-df, za2.graphql, za5.graphql, za8.blob, ze7.msit-table, ze9.dxt-onelake, zebr-a-web-uat, zeus.buddy, and zeus.buddy. Below the list, there are two error messages: "[*] Performing SecurityScorecard scan ... Read api-keys.yaml from /etc/theHarvester/api-keys.yaml An exception has occurred in SecurityScorecard scanning: [!] Missing API key for SecurityScorecard." and "[*] Performing BuiltWith scan ... Read api-keys.yaml from /etc/theHarvester/api-keys.yaml [!] Missing API key for BuiltWith." The terminal prompt is (kali@kali)~\$.

```
Session Actions Edit View Help
za0.onelake.fabric-df
za2.graphql
za5.graphql
za8.blob
ze7.msit-table
ze9.dxt-onelake
zebr-a-web-uat
zeus.buddy
zeus.buddy

[*] Performing SecurityScorecard scan ...
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
An exception has occurred in SecurityScorecard scanning:
[!] Missing API key for SecurityScorecard.

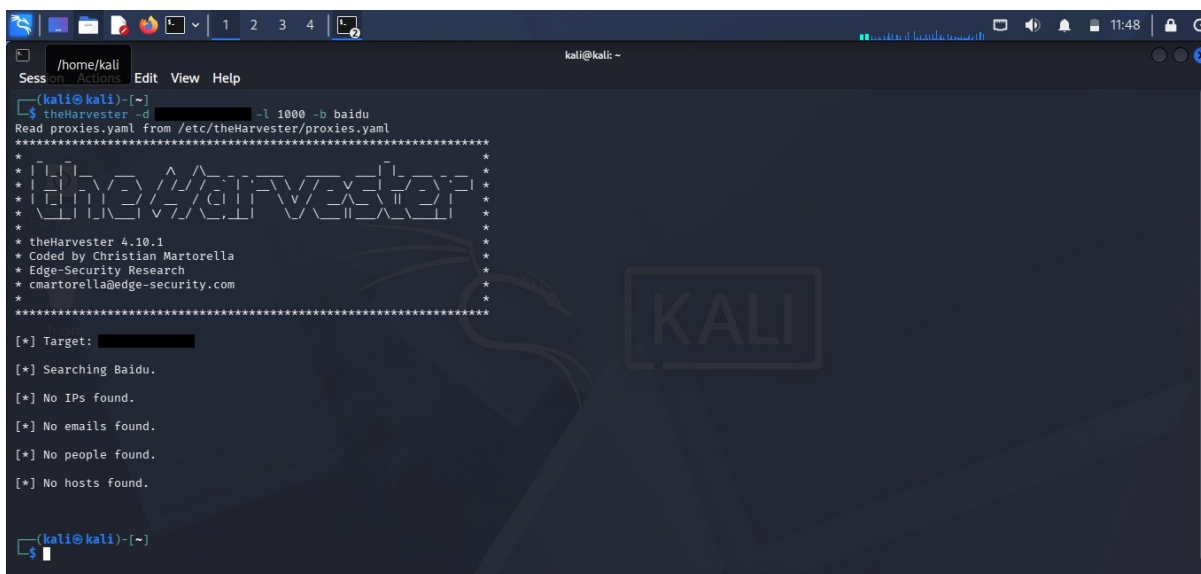
[*] Performing BuiltWith scan ...
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for BuiltWith.

(kali@kali)~$
```

Figure 2: Enumerated subdomains and subsequent API-key errors (11:25)

3.3 Source-specific scan – Baidu

A targeted scan was also run against a single source using theHarvester -d <target-domain> -l 1000 -b baidu. This query returned no IPs, emails, people, or hosts, indicating that the Baidu search engine indexes little to no information about the target domain — an expected result given Baidu is a Chinese search engine with limited coverage of most Western enterprise domains.

A terminal window on a Kali Linux system showing the output of a targeted theHarvester scan. The command used is theHarvester -d [redacted] -l 1000 -b baidu. The output shows the tool's version (4.10.1), the coder (Christian Martorella), and the organization (Edge-Security Research). It then displays the target domain and the search results: "[*] Searching Baidu. [*] No IPs found. [*] No emails found. [*] No people found. [*] No hosts found." The terminal prompt is (kali@kali)~\$.

```
Session Actions Edit View Help
(kali@kali)~$ theHarvester -d [redacted] -l 1000 -b baidu
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
* theHarvester 4.10.1
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*
[*] Target: [redacted]
[*] Searching Baidu.
[*] No IPs found.
[*] No emails found.
[*] No people found.
[*] No hosts found.

(kali@kali)~$
```

Figure 3: theHarvester scan restricted to the 'baidu' source – no results returned (11:48)

3.4 Repeat scan – all sources

The all-source scan was repeated later to confirm consistent behaviour. The same set of "Missing API key" errors was observed for sources requiring paid API access, confirming this was an environment/configuration limitation rather than a transient network issue.

```
kali@kali: ~  
$ theHarvester -d [REDACTED] -l 50 -b all  
Read proxies.yaml from /etc/theHarvester/proxies.yaml  
*****  
* [REDACTED] *  
* [REDACTED] *  
* [REDACTED] *  
* [REDACTED] *  
* theHarvester 4.10.1 *  
* Coded by Christian Martorella *  
* Edge-Security Research *  
* cmartorella@edge-security.com *  
*****  
[*] Target: [REDACTED]  
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml  
Failed to process bevigil search for word: [REDACTED]  
Error Message:  
[!] Missing API key for bevigil.  
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml  
[!] Missing API key for Bitbucket.  
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml  
Failed to process bufferoverrun search for word: [REDACTED]  
Error Message:  
[!] Missing API key for bufferoverrun.  
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml  
Failed to perform BuiltWith search for word: [REDACTED]  
A Missing Key Error occurred in builtwith:
```

Figure 4: Repeat run of theHarvester with '-b all' (11:58)

4. Part B – Active Host Discovery with Nmap / Zenmap

The Zenmap GUI (a graphical front-end for Nmap) was used to perform a ping sweep across a lab subnet to identify live hosts before any port-level scanning. The subnet and host IP addresses have been redacted throughout this report.

4.1 Ping scan execution

The scan profile "**Ping scan**" was selected, which Zenmap translated into the underlying command `nmap -sn <subnet>/24`. This performs host discovery only (ICMP/ARP probes), without scanning any ports. Out of 256 possible addresses in the /24 range, the scan completed in 8.12 seconds and identified 2 hosts as up, one of which returned a resolvable MAC address.

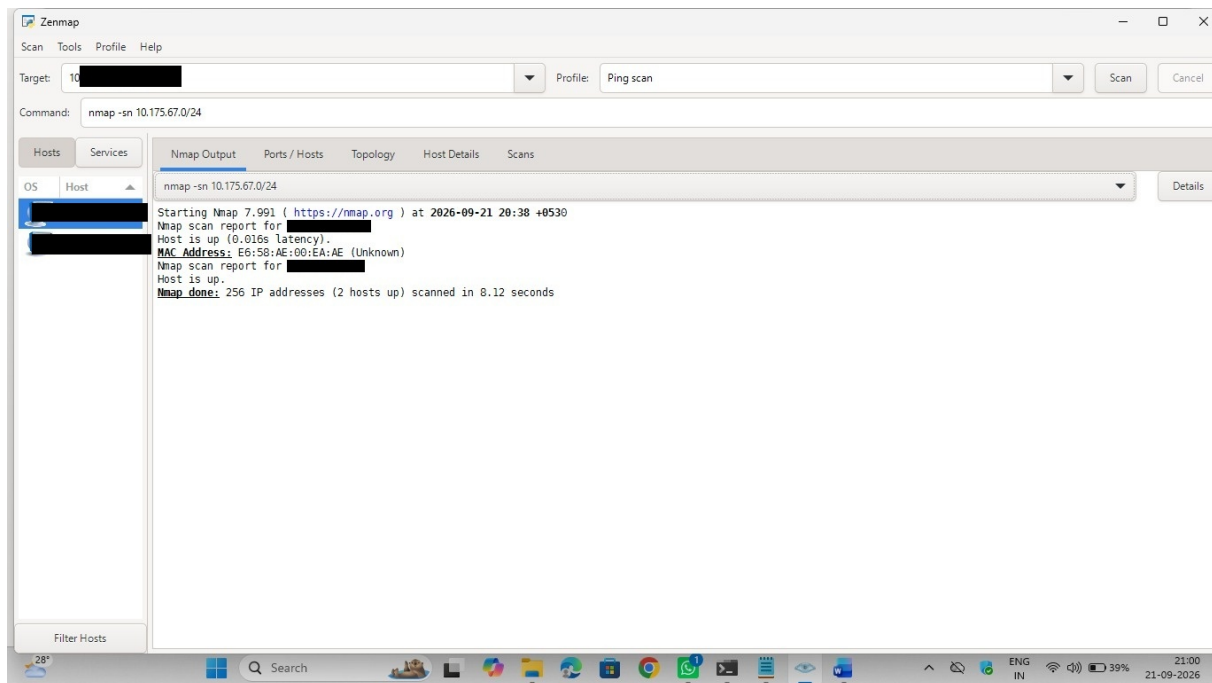


Figure 5: Zenmap 'Nmap Output' tab showing the ping scan results — 2 hosts up (21:00)

4.2 Network topology view

Zenmap's built-in **Topology** tab was used to visualise the discovered hosts relative to the scanning machine (localhost). Both live hosts appeared as directly connected nodes on the same broadcast segment, confirming they reside on the same local /24 network as the attacking machine.

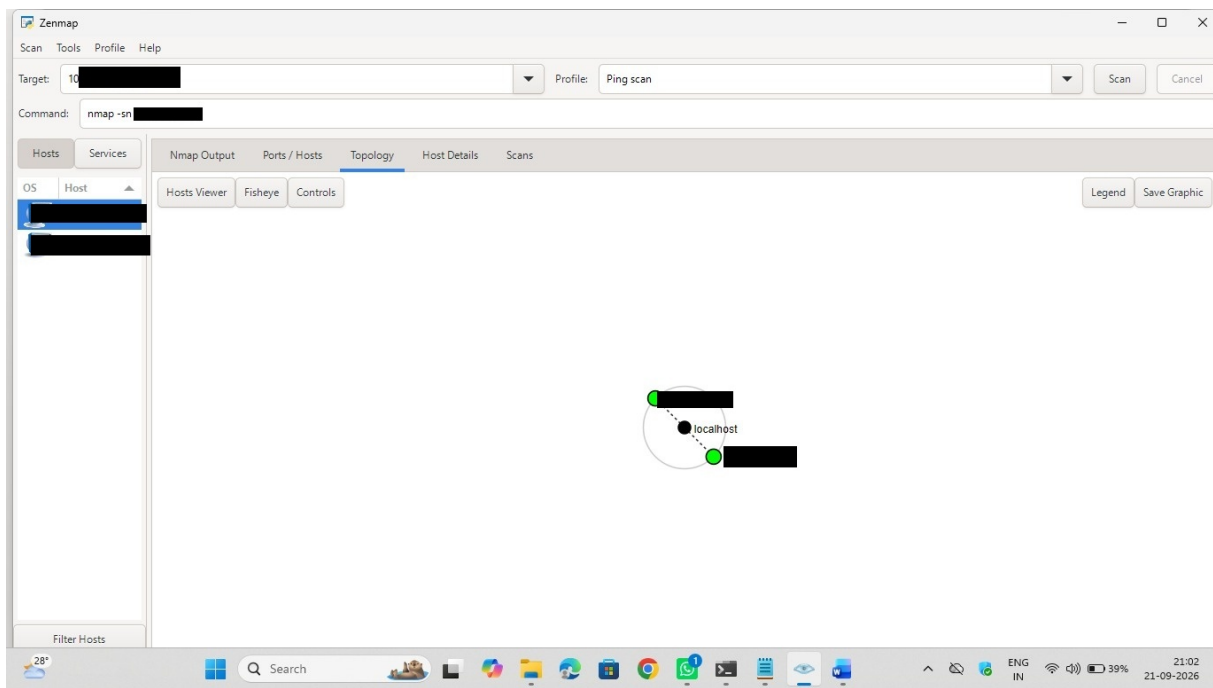


Figure 6: Zenmap 'Topology' tab showing discovered hosts relative to localhost (21:02)

5. Summary of Findings

#	Finding	Observation
1	OSINT subdomain exposure	Numerous internal-looking subdomains for cloud/API infrastructure were discoverable via free OSINT sources without any authentication.
2	Incomplete tool configuration	Several theHarvester sources (bevigil, Bitbucket, bufferoverrun, BuiltWith, SecurityScorecard) require API keys not configured in this lab, limiting result completeness.
3	Source coverage varies	Not all OSINT sources index every target equally — the Baidu source returned no data at all, highlighting the value of querying multiple sources.
4	Live hosts on lab subnet	A ping sweep of the /24 lab subnet identified 2 live hosts, forming the basis for follow-on port/service scanning.

6. Recommendations

- Configure API keys for the missing OSINT sources (bevigil, Bitbucket, bufferoverrun, BuiltWith, SecurityScorecard) to improve reconnaissance coverage in future assignments.
- Cross-reference results from multiple OSINT sources rather than relying on a single engine, since coverage varies significantly (e.g. Baidu returned nothing).
- Use the two hosts identified in the ping sweep as targets for a follow-up port and service scan (e.g. nmap -sV -sC) in the next stage of the assessment.
- Organisations should periodically audit publicly discoverable subdomains to ensure no unintended internal systems are exposed to OSINT enumeration.

7. Conclusion

This assignment demonstrated the first two stages of the penetration testing methodology: passive OSINT reconnaissance and active host discovery. theHarvester successfully enumerated a range of subdomains from free sources despite missing API keys for several premium integrations, while the Zenmap ping sweep confirmed two live hosts on the lab subnet. These results provide a foundation for the next phase of the assessment — targeted port scanning and service enumeration on the discovered hosts.